Fase 0 — Alcance, supuestos y clasificación

Resumen del caso, alcance, confidencialidad y metas del SOC N1

Caso	C23 — TalentoRemoto Staffing TI S.A.S. (empresa ficticia, 10 empleados, 20 equipos)
Consultor(es)	Angel David Rey Duran
Programa / institución	Ingeniería de Sistemas — Unidades Tecnológicas de Santander
Versión / fecha	

1. Resumen del caso

TalentoRemoto Staffing TI S.A.S. es una empresa ficticia de outsourcing de talento TI que opera **100 % de forma remota**: no tiene oficina física y sus 10 empleados trabajan desde redes domésticas. Su infraestructura se concentra en la nube (Microsoft 365 y una VPN de acceso remoto) y en 20 equipos de cómputo: 10 portátiles Windows 11 y 2 estaciones Windows 11 (administración y RR. HH.), 4 portátiles macOS, 2 portátiles Ubuntu, 1 servidor Ubuntu en la nube (VPN y gateway) y 1 Windows Server en la nube (identidad). Sus activos críticos son las identidades, la VPN y los portátiles de los consultores; maneja hojas de vida y datos personales de candidatos y empleados (Ley 1581 de 2012) y accesos a sistemas de clientes protegidos por contratos de confidencialidad.

El riesgo particular del caso es la combinación de **redes domésticas inseguras, credenciales robadas y equipos fuera de control**. La madurez de seguridad actual es baja y el presupuesto es limitado: **CAPEX ≤ COP 20 M y OPEX ≤ COP 1,5 M/mes**. Los tres escenarios de alerta a triagear son: (1) inicio de sesión (VPN) desde un país inusual, (2) infostealer bloqueado por el EDR y (3) agente de seguridad detenido sin ticket asociado.

2. Supuestos adicionales

- Los 20 equipos son: 18 equipos de usuario (16 portátiles y 2 estaciones) y 2 servidores en la nube; los equipos de usuario rotan entre los consultores en misión y el personal administrativo, por lo que cada activo tiene un propietario por rol (pool) y no una persona fija.
- Los 10 empleados son: gerente general (E01), coordinador de RR. HH. (E02), administrador de TI y responsable del SOC (E03) y 7 consultores TI (E04–E10). Todos los nombres son ficticios.
- Los agentes se conectan al SIEM a través de la VPN (preferido) o por Internet con TLS cuando la VPN no esté disponible; el plan define el comportamiento de un agente desconectado (ver Fase 6).
- El laboratorio representa el caso con VM propias: SIEM, consola Kaspersky, un endpoint Windows 11 y uno Ubuntu. Los equipos macOS y los servidores en la nube se documentan en el plan de despliegue; la compatibilidad de los agentes con macOS se verifica en la documentación oficial vigente.
- Microsoft 365 es un servicio SaaS: el límite de responsabilidad con el proveedor se documenta en la Fase 1; en el laboratorio no se toca ningún tenant real.
- No existe NGFW físico: se cotiza una opción virtual o en la nube (la guía del caso lo permite) además de equipos físicos como referencia comparativa.
- Zona horaria única America/Bogota y sincronización NTP en todos los equipos.

•

3. Alcance

Elemento	Detalle
Activos incluidos	Los 20 equipos del caso (en laboratorio: SRV-C23-SIEM, SRV-C23-KSC, PC-C23-01, UBU-C23-01; el resto como plan de despliegue), los servicios en la nube (VPN, identidad, GLPI GLP-C23) y Microsoft 365 a nivel de plan de recolección de logs.
Elemento	**Detalle**
Activos excluidos	Sistemas de terceros y de la institución, Internet, tenant real de M365, redes domésticas reales, datos reales de cualquier persona.
Ubicaciones	Sin oficina física. Laboratorio: red virtual aislada (host-only o NAT interna) en el equipo del estudiante; GLPI en una instancia de nube propia.
Horario de monitoreo	Lunes a viernes 7:00–19:00 (America/Bogota) con dos analistas en traslape; guardia por notificación para crítica y alta fuera de horario (ver Manual SOC N1).
Actividades permitidas	Instalación y configuración; eventos de prueba controlados (FIM, fallos de autenticación, EICAR, detención del agente, acceso desde IP no autorizada simulada); consulta de reputación pública.
Actividades prohibidas	Escaneos o ataques fuera de las VM propias, uso de datos reales, exposición de secretos, carpetas compartidas con el anfitrión, acciones ofensivas.

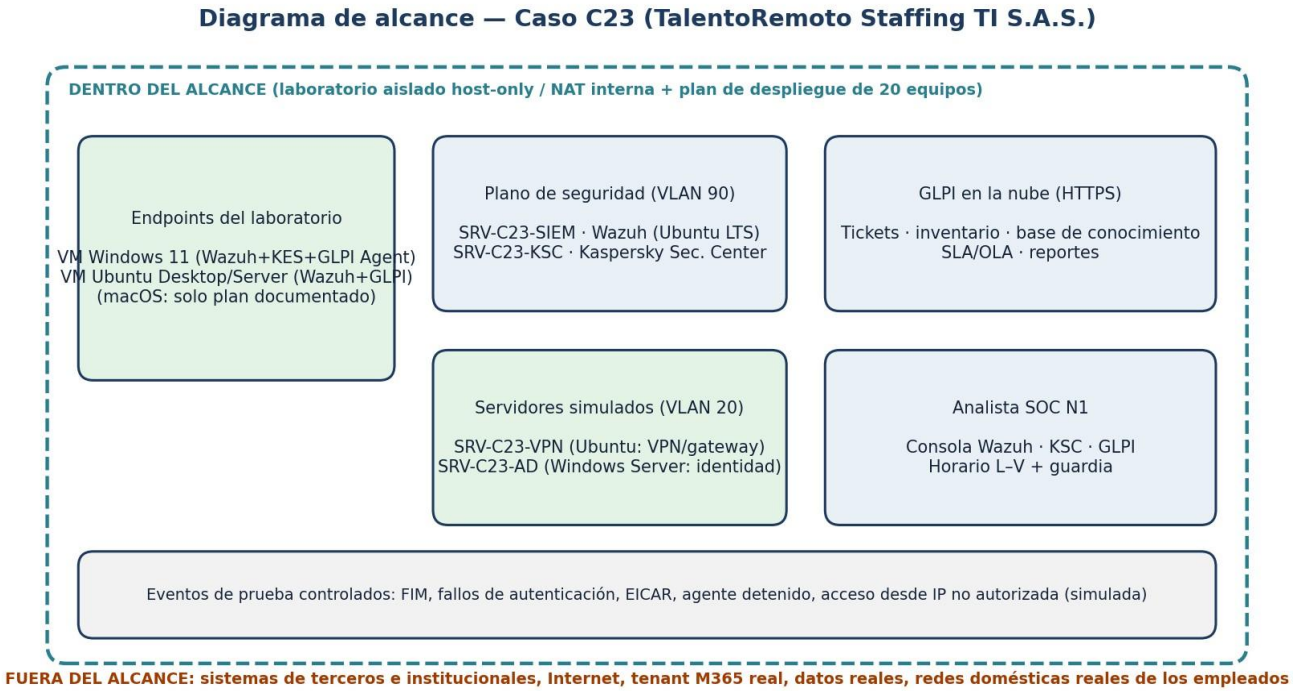


Figura 1. Diagrama de alcance (una página).

4. Confidencialidad y clasificación de la información

Nivel	Ejemplos en C23	Tratamiento
Pública	Descripción comercial de la empresa ficticia, material de concienciación sin datos internos.	Sin restricción.
Interna	Procedimientos del SOC, playbooks, manual, KPI agregados.	Acceso solo del personal de la empresa; repositorio privado.
Confidencial	Logs del SIEM y del EDR, tickets de GLPI, inventario con hostnames e IP, configuraciones sin secretos.	Acceso por rol (N1 lectura, responsable SOC administración); retención 90 días en el SIEM y 12 meses archivados; respaldo cifrado.
Restringida	Credenciales, llaves, tokens, hojas de vida y datos personales de candidatos y empleados (ficticios en el ejercicio), evidencias forenses (.eml, hashes asociados a usuarios).	Nunca en informes, video o repositorio; marcadores en lugar de valores reales; acceso mínimo; en un caso real aplica la Ley 1581 (autorización, finalidad, seguridad).

Los logs, los tickets y las evidencias se tratan como **Confidenciales** por defecto; las capturas de pantalla se revisan antes de publicarse para ocultar contraseñas, tokens, correos personales e IP públicas reales. Los correos de phishing se guardan como archivos .eml en un repositorio seguro y no se adjuntan al ticket sin necesidad.

5. Alcance del SOC N1 y metas iniciales

Qué cubre	Qué no cubre	Metas iniciales
Monitoreo de alertas de Wazuh, Kaspersky y NGFW; triage y documentación en GLPI; contención básica permitida a N1; escalamiento a N2; mejora de reglas.	Análisis forense, ingeniería inversa, respuesta ofensiva, gestión de parches en producción, administración de M365 y de cuentas privilegiadas (corresponde a N2 / TI con ticket de cambio).	Cobertura de agentes 100 % de los 20 equipos (meta ≥ 98 %); ≥ 90 % de tickets dentro del SLA; 9 playbooks publicados en la base de conocimiento; 3 o más reglas personalizadas operativas; tasa de falsos positivos en descenso.

Marco de referencia: Ley 1273 de 2009, Ley 1581 de 2012, ISO/IEC 27001:2022 (Anexo A) y NIST CSF 2.0. El inventario de activos está en el Anexo A y la matriz de riesgos en el Anexo B; la carta de autorización es el Anexo H.